

ID	Threat Event	Vulnerability	Likelihood (1-5)	Impact (1-5)	Risk Score (L × I)	Inherent Risk Lc	Mitigation Strategy / Control	Residual Risk
RSK-01	Ransomware Infection	Outdated unpatched OS binaries & lack of immutable backups	4	5	20	High	Implement endpoint detection and response (EDR), enforce offline air-gapped backups, and schedule automated patch management.	Low (6)
RSK-02	Cloud Storage Misconfiguration	S3 buckets or Notion databases set to public visibility	3	4	12	Medium	Deploy Cloud Access Security Broker (CASB) automated scanners and enforce least-privilege identity access management (IAM).	Low (3)
RSK-03	Credential Stuffing / Phishing	Employees reusing passwords and lacking multi-factor authentication	4	4	16	High	Enforce mandatory phishing-resistant MFA (hardware keys or authenticator apps) and deploy automated identity protection tools.	Low (4)
RSK-04	Third-Party Vendor Data Leak	SaaS vendor lacking SOC 2 compliance handling client PII	3	4	12	Medium	Establish a formal vendor risk management (VRM) lifecycle; require annual security questionnaires and compliance audits.	Low (4)
RSK-05	Unauthorized Insider Threat	Excessive root privileges assigned to general development staff	2	5	10	Medium	Apply strict Principle of Least Privilege (PoLP), implement Just-In-Time (JIT) access, and log administrative actions.	Low (2)